

UNIVERSIDAD DE LAS PALMAS DE GRAN CANARIA
Escuela de Ingeniería Informática

Práctica 8:
Amenazas a la Seguridad Digital

Asignatura: Seguridad de la Información

Curso: 4º de Grado en Ingeniería Informática

Autor:

Nicolás Rey Alonso

`nicolas.rey101@alu.ulpgc.es`

Fecha: Abril 2026

Índice general

1. Introducción	2
1.1. Objetivos de la práctica	2
1.2. Fundamentos teóricos	2
1.3. Enunciado de la práctica	3
2. Phishing, estafas a través de la red	4
3. Malware difundido en redes sociales	7
4. Ataques de ransomware contra corporaciones y gobiernos	10
5. Botnets, ordenadores zombies	13
6. Malware en dispositivos móviles	15

Capítulo 1

Introducción

1.1. Objetivos de la práctica

El objetivo fundamental de esta práctica es la obtenención de información y familiarización con las amenazas a la seguridad digital.

1.2. Fundamentos teóricos

Para la realización de esta práctica, se aplican diversos conceptos teóricos clave de la ciberseguridad y la seguridad de la información, entre los que destacan:

- **Conocimiento de los CVE/CWE:** CVE (Common Vulnerabilities and Exposures) es un sistema de identificación de vulnerabilidades conocido a nivel mundial, mientras que CWE (Common Weakness Enumeration) clasifica las debilidades de software. Familiarizarse con estas bases de datos es esencial para entender las amenazas actuales y cómo mitigarlas.
- **Phishing:** Técnica de ingeniería social utilizada para engañar a los usuarios y obtener información confidencial, como contraseñas o datos bancarios, a través de correos electrónicos, mensajes o sitios web falsos.
- **Malware:** Software malicioso diseñado para dañar, explotar o comprometer sistemas informáticos. Puede incluir virus, troyanos, ransomware, spyware, entre otros.
- **Ransomware:** Tipo de malware que cifra los archivos de la víctima y exige un rescate para restaurar el acceso a los datos. Es una amenaza creciente para empresas y particulares.

- **Botnets:** Redes de dispositivos comprometidos (ordenadores zombies) controlados por un atacante para realizar actividades maliciosas, como ataques DDoS, envío de spam o minería de criptomonedas.
- **SQL Injection:** Vulnerabilidad que permite a un atacante ejecutar código SQL malicioso en una base de datos a través de una aplicación web, lo que puede resultar en la exposición o manipulación de datos sensibles.
- **Cross-Site Scripting (XSS):** Vulnerabilidad que permite a un atacante inyectar scripts maliciosos en páginas web vistas por otros usuarios, lo que puede llevar al robo de cookies, secuest

1.3. Enunciado de la práctica

Esta práctica consiste en la realización de un informe basado en una selección de noticias de prensa digital, posteriores al 1 de enero de 2025, relacionadas con una serie de amenazas informáticas.

Las amenazas objeto de esta actividad serán:

1. Phishing, estafas a través de la red
2. Malware difundido en redes sociales
3. Ataques de ransomware contra corporaciones y gobiernos
4. Botnets, ordenadores zombies
5. Malware en dispositivos móviles
6. Inyección de código SQL
7. Cross-Site Scripting (XSS)

Capítulo 2

Phishing, estafas a través de la red

Detalles de la Noticia

Breve descripción de la amenaza:

El phishing es una de las amenazas informáticas más persistentes y efectivas, ya que explota la psicología humana en lugar de vulnerabilidades técnicas. Se trata de un tipo de ingeniería social donde los atacantes se hacen pasar por entidades legítimas como bancos, compañeros de trabajo o servicios conocidos como Microsoft para engañar a la víctima y lograr que revele información sensible.

La técnica consiste generalmente en enviar correos electrónicos fraudulentos, mensajes de texto o crear sitios web idénticos a los reales. Estos mensajes suelen utilizar tácticas de urgencia o miedo para forzar a la víctima a actuar sin pensar críticamente. El objetivo final es manipular al usuario para que haga clic en enlaces maliciosos (que instalan malware), ingrese sus credenciales de inicio de sesión, o transfiera dinero.

El éxito del phishing radica en explotar la confianza; si una víctima asume que el mensaje proviene de una fuente confiable, es mucho más probable que caiga en la trampa. Este ataque sirve como punto de partida para innumerables amenazas, ya que comprometer las credenciales robadas abre la puerta a ataques de ransomware, inyección de código SQL y el robo de identidad a gran escala.

Fecha de la noticia: 27/01/2026

Título de la noticia: [Theres a rash of scam spam coming from a real Microsoft address](#)

Enlace a la noticia: <https://arstechnica.com/information-technology/2026/01/theres-a-rash-of-scam-spam-coming-from-a-real-microsoft-address/>

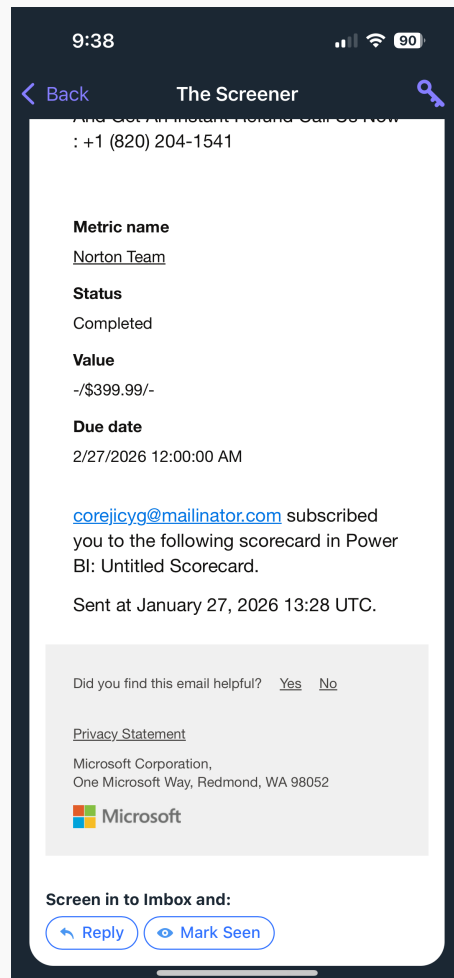
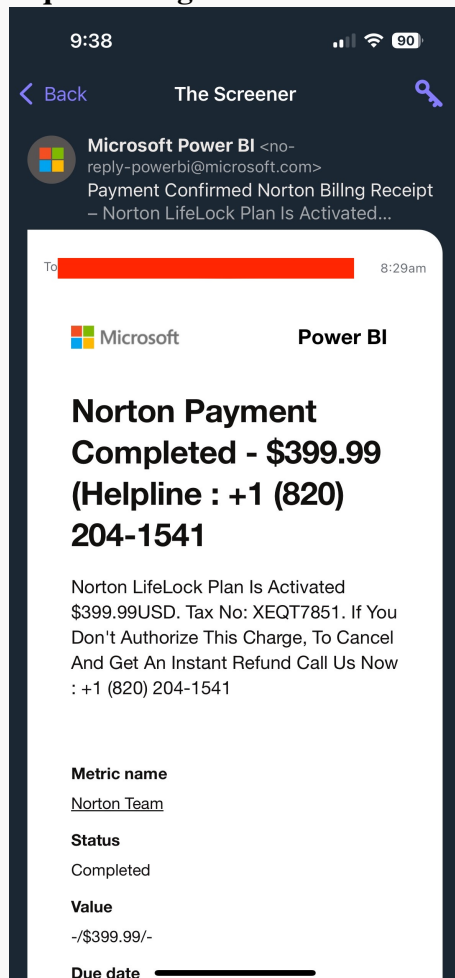
Medio: Noticiario digital estadounidense especializado en noticias tecnológicas: “arstechnica.com”

Enlace al medio: <https://arstechnica.com>

Nacionalidad del medio: Estados Unidos

Idioma de la noticia: Inglés

Pequeña imagen de la noticia:



Breve resumen de la noticia: Reportes recientes indican un aumento en el envío de spam fraudulentos originados desde una dirección de correo electrónico legítima de Microsoft. Específicamente, los correos maliciosos provienen de una cuenta vinculada a Power BI, como no-reply-powerbi@microsoft.com. Debido a que Microsoft aconseja a los usuarios añadir estas direcciones a sus listas de permitidos para evitar el bloqueo por filtros de spam, los atacantes están abusando de este consejo para llevar a cabo estafas sofisticadas. Los ciberdelincuentes explotan la función de Power BI que permite agregar direcciones externas como suscriptores de informes. Este abuso les confiere una capa adicional de credibilidad a las estafas de ingeniería social. En el caso reportado, los correos se disfrazaron de notificaciones sobre cargos falsos y proporcionaron un número de teléfono para disputar la transacción. La víctima del phishing, al interactuar con el estafador por teléfono, fue dirigida a descargar aplicaciones de acceso remoto, lo que permite a los atacantes tomar control total de los sistemas operativos (Mac o Windows).

Esta técnica es peligrosa porque utiliza la infraestructura de Microsoft como fachada, lo que facilita evadir la detección automática de seguridad y hacer que las estafas parezcan más creíbles. Además, se ha descubierto que otras empresas, como Google, también han enfrentado campañas similares de abuso de plataformas en la nube para distribuir phishing. Como respuesta a este problema, Microsoft temporalmente deshabilitó la función de suscripción por correo electrónico mientras desarrollan una solución a largo plazo.

Relación con la amenaza: El phishing es el vector de ataque más común y la puerta de entrada principal para todas las amenazas mencionadas. Al explotar la confianza (como la que se genera al usar direcciones legítimas), los atacantes engañan a las víctimas para obtener credenciales, tokens de autenticación y acceso inicial.

¿Existe CVE o CWE asociado a la noticia? No

Impacto ocasionado por la amenaza en esta noticia (más de 100 palabras): El impacto de esta amenaza se manifiesta en costos masivos y múltiples frentes. Para los individuos y las PYMES, el daño económico es severo: un solo robo puede oscilar entre 9.000 y más de 80.000 en una sola noche. Además, el fraude empresarial (BEC) resultante de estas estafas puede generar pérdidas promedio de \$128.000 por transacción.

Para Microsoft, el impacto es financiero y reputacional; la compañía debe invertir miles de millones para mitigar el abuso de su infraestructura. Finalmente, el ecosistema de ciberseguridad soporta una carga adicional: la identificación y contención de estas brechas tarda en promedio 241 días, lo que añade aproximadamente \$1.2 millones de costos adicionales por retraso en la detección. Esta situación obliga a las empresas a aumentar sus presupuestos de TI entre un 10% y 15% anualmente para implementar soluciones avanzadas y formación humana, ante la obsolescencia de protocolos de seguridad tradicionales.

Capítulo 3

Malware difundido en redes sociales

Detalles de la Noticia

Breve descripción de la amenaza: El Malware (software malicioso) es el término genérico que se utiliza para describir cualquier tipo de software diseñado específicamente para causar daño, obtener acceso no autorizado a sistemas informáticos o realizar acciones maliciosas en un dispositivo. Esta categoría abarca una amplia gama de amenazas, incluyendo virus, troyanos, ransomware, spyware y rootkits. Su objetivo final es explotar vulnerabilidades en los sistemas operativos y aplicaciones para comprometer la confidencialidad, integridad y disponibilidad de los datos. El malware actúa como el vector de ataque, siendo el programa ejecutable que se instala en el sistema víctima para llevar a cabo las operaciones del atacante.

El Infostealer (ladrón de información) es una clase específica y muy enfocada de malware. Su función principal no es simplemente destruir datos (como lo hace un ransomware), sino extraer activamente la información sensible almacenada en los sistemas comprometidos. Los infostealers están diseñados para buscar y recopilar credenciales de inicio de sesión (nombres de usuario y contraseñas), tokens de sesión, claves privadas, números de tarjetas de crédito, datos bancarios y archivos personales. Estos programas se especializan en la exfiltración de esta información a un servidor externo controlado por el atacante, buscando facilitar el fraude financiero, el robo de identidad o el espionaje corporativo.

Fecha de la noticia: 02/07/2026

Título de la noticia: <https://www.welivesecurity.com/es/malware/infostealers-presentes-latinoamerica-2025/>

Enlace a la noticia: <https://www.welivesecurity.com/es/malware/infostealers-presentes-latinoamerica-2025/>

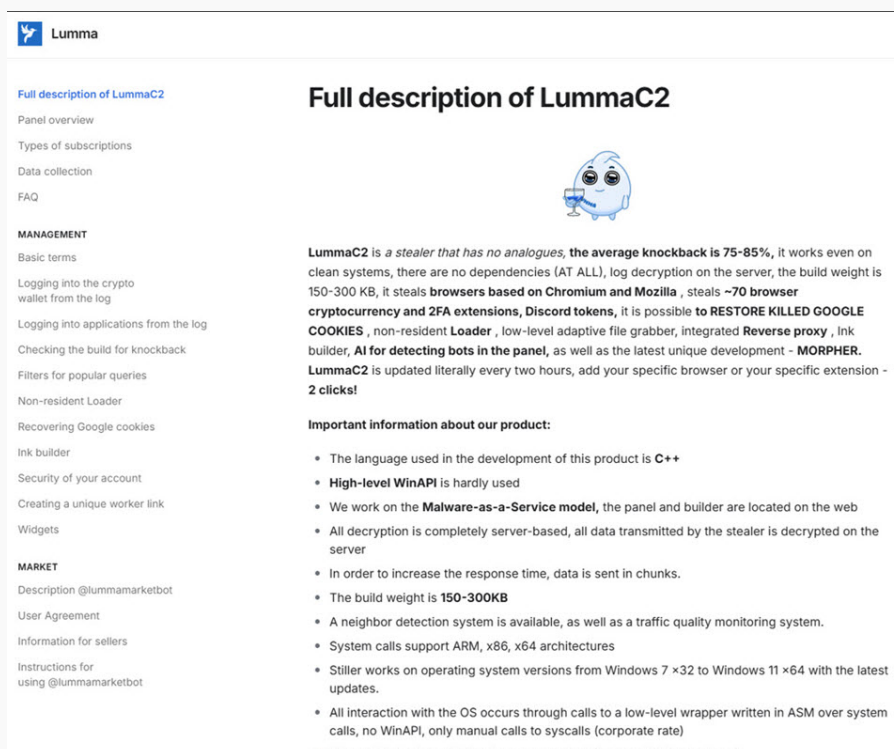
Medio: Welivesecurity, blog de seguridad informática de la empresa de ciberseguridad

ESET.

Enlace al medio: <https://www.welivesecurity.com>

Nacionalidad del medio: Bratislava, Eslovaquia.

Idioma de la noticia: Español **Pequeña imagen de la noticia:**



Breve resumen de la noticia:

El análisis detalla una evolución sofisticada de diversas familias de malware clave, incluyendo Amadey, reconocido como puerta de entrada inicial; Rozena, un stealer file-less que garantiza una persistencia sigilosa; Guildma, un troyano bancario regional enfocado en la interceptación transaccional; Formbook y su evolución a XLoader, que representan herramientas avanzadas de extracción de datos. El foco central de esta actividad es el robo sistemático de credenciales de acceso y datos financieros sensibles.

Se enfatiza cómo estos actores maliciosos han adoptado un enfoque dual: utilizan métodos de distribución modernos, explotando la confianza humana a través del phishing dirigido y aprovechando canales de comunicación como Discord para la propagación rápida entre comunidades cibernéticas. Esta combinación con técnicas evasivas les permite operar con una eficacia considerable en el entorno latinoamericano, donde las defensas suelen ser menos robustas frente a estas tácticas. La evolución constante de estos malwares demuestra la capacidad adaptativa de los atacantes para sortear las medidas de seguridad tradicionales y maximizar el impacto del fraude cibernético.

Relación con la amenaza:

La noticia es un ejemplo práctico y detallado de la clase de malware conocida como ****Infostealer****. Mientras que el Malware es el término genérico para cualquier software malicioso, los Infostealers son su subconjunto especializado cuyo objetivo principal es la extracción activa de información sensible (credenciales, tokens, datos bancarios). La noticia ilustra esto al nombrar familias específicas (LummaStealer, Amadey, etc.) y detallar sus métodos de operación. Estos ejemplos demuestran cómo el concepto teórico se aplica en un contexto real: los atacantes utilizan vectores modernos como el ***phishing*** o canales anónimos como Discord para ejecutar la función central del infostealer: la exfiltración de datos. La evolución constante de estas amenazas, desde troyanos bancarios hasta herramientas ***file-less***, subraya la capacidad adaptativa y el riesgo persistente que representan para la seguridad digital.

¿Existe CVE o CWE asociado a la noticia? No

Impacto ocasionado por la amenaza en esta noticia:

El impacto principal es la exposición masiva de datos sensibles, incluyendo credenciales bancarias, información personal y detalles del sistema comprometido. Las amenazas como Guildma están específicamente diseñadas para interceptar sesiones bancarias, mientras que los infostealers (Formbook, XLoader) se enfocan en extraer credenciales de navegadores y clientes de correo electrónico. La capacidad de estos malwares para operar de manera **"file-less"** y su distribución a través de plataformas como Discord permiten una persistencia y evasión significativas. Esto pone en riesgo la seguridad financiera de individuos y organizaciones, exigiendo una respuesta urgente mediante inteligencia de amenazas proactiva y mecanismos de detección avanzada.

Capítulo 4

Ataques de ransomware contra corporaciones y gobiernos

Detalles de la Noticia

Breve descripción de la amenaza:

El ransomware es una de las amenazas más destructivas y lucrativas en el panorama de la ciberseguridad moderna. Se clasifica como un tipo de malware cuyo objetivo principal no es robar información (como un infostealer), sino denegar el acceso a los datos o sistemas críticos mediante el cifrado criptográfico.

Una vez que un atacante logra infiltrarse en una red, el ransomware ejecuta su carga útil: cifra archivos vitales del sistema operativo, bases de datos y copias de seguridad. Este proceso convierte la información legible en galimatías inútiles sin la clave de descifrado. Posteriormente, los atacantes exigen un rescate (el ransom") a cambio de proporcionar dicha clave.

La sofisticación actual va más allá del simple cifrado; muchos ataques combinan el cifrado con la doble extorsión: además de bloquear el acceso, roban copias de los datos antes de cifrarlos y amenazan con publicarlas si no se paga el rescate. Esto aumenta drásticamente la presión sobre las víctimas, ya que el riesgo pasa de ser solo operativo a reputacional y legal. La prevención requiere una combinación robusta de copias de seguridad offline, sistemas de detección avanzados y políticas de acceso estrictas.

Fecha de la noticia: 15/04/2026

Título de la noticia:

Manufacturing absorbs 56 % ransomware surge of global attacks in 2025, as RaaS, legacy OT, supply chains fuel spike

Enlace a la noticia:

<https://industrialcyber.co/manufacturing/manufacturing-absorbs-56-ransomware-surge-of-global-attacks-in-2025-as-raas-legacy-ot-supply-chains-fuel-spike/>

Medio: Industrial Cyber, blog de seguridad informática.

Enlace al medio: <https://industrialcyber.co>

Nacionalidad del medio: Estados Unidos.

Idioma de la noticia: Inglés **Pequeña imagen de la noticia:**



Breve resumen de la noticia:

El sector manufacturero ha sido un objetivo crítico y está absorbiendo una parte desproporcionada del aumento global de ataques de ransomware. Según el informe de Check Point Research, los incidentes en este sector aumentaron un 56

Este auge se debe a tres factores estructurales: la persistencia de sistemas OT (tecnología operativa) heredados con vulnerabilidades conocidas; la creciente complejidad de las cadenas de suministro que expanden la superficie de ataque; y la maduración del modelo RaaS (ransomware-as-a-service). Los atacantes están utilizando tácticas avanzadas como la doble extorsión, el robo de datos sensibles y el uso de IA para maximizar la presión financiera.

El impacto es devastador, ya que una interrupción operativa puede costar millones por día. Para mitigar este riesgo, se recomienda urgentemente implementar arquitecturas de confianza cero (zero-trust) en entornos IT y OT, priorizar el parcheo rápido de vulnerabilidades críticas y mantener copias de seguridad inmutables y aisladas para garantizar la capacidad de recuperación sin recurrir al pago de rescates.

Relación con la amenaza:

Esta noticia es un ejemplo de cómo el **Ransomware** se manifiesta como una amenaza crítica y altamente disruptiva dentro del espectro general del Malware. Mientras que

los Infostealers (como se describió anteriormente) se especializan en la exfiltración silenciosa de datos sensibles para fraude financiero, el Ransomware tiene como objetivo principal negar el acceso a sistemas críticos mediante el cifrado de información vital. El impacto no es solo el robo de datos, sino la paralización operativa completa, lo cual, según el artículo, puede costar millones por día. La noticia proporciona evidencia concreta al reportar un aumento del 56% en ataques contra el sector manufacturero, señalando que los atacantes explotan vulnerabilidades específicas como sistemas OT (tecnología de operación) y cadenas de suministro complejas para maximizar la presión económica sobre las víctimas. En esencia, demuestra cómo el malware puede evolucionar desde el robo discreto de datos hasta la interrupción masiva de servicios esenciales.

¿Existe CVE o CWE asociado a la noticia? No

Impacto ocasionado por la amenaza en esta noticia:

El impacto de los ataques de ransomware trasciende la mera pérdida de datos cifrados; es una crisis multifacética que afecta la continuidad operativa, la estabilidad financiera y la confianza en las instituciones.

A nivel operativo, el efecto más inmediato es la paralización total de procesos críticos y los costes de recuperación de datos que oscilan de los 4000\$ a los 70000\$. Al cifrar sistemas SCADA o PLCs (controlando maquinaria industrial), se detienen líneas de producción enteras, como ocurrió con productores de acero o fabricantes de dispositivos médicos. Esta interrupción no solo genera pérdidas directas por inactividad, sino que también afecta a toda la cadena de suministro asociada.

Financieramente, el costo es doble: incluye el pago del rescate (si se decide hacerlo) y los gastos masivos en recuperación forense y restauración de sistemas. Sin embargo, el daño más profundo es el impacto reputacional y la pérdida de confianza. Además, con las tácticas modernas de doble extorsión, el robo de datos sensibles como información de pacientes o secretos comerciales puede llevar a multas regulatorias millonarias y un colapso en el valor bursátil de la empresa afectada. En esencia, estos ataques amenazan la infraestructura económica y social completa

Capítulo 5

Botnets, ordenadores zombies

Detalles de la Noticia: DoJ Disrumpe Botnets IoT por DDoS Globales

Breve descripción de la amenaza: Una botnet es una red de dispositivos informáticos (ordenadores, smartphones, routers, IoT) que han sido comprometidos y controlados remotamente por un atacante, conocido como "botmaster". Estos dispositivos infectados se convierten en "bots" o "zombies", que son utilizados para ejecutar tareas maliciosas que benefician al atacante.

Los ordenadores zombies (o bots) son los nodos individuales dentro de esta red. Un ordenador zombie es esencialmente una máquina que ha sido infectada con malware (como bots, worms o Trojans) y se ejecuta silenciosamente, realizando comandos sin el conocimiento del usuario. El atacante utiliza un servidor central, llamado infraestructura de comando y control (C2), para enviar órdenes a todos los zombies simultáneamente.

Fecha de la noticia: 20 de Marzo de 2026

Título de la noticia: DoJ Disrupts 3 Million-Device IoT Botnets Behind Record 31.4 Tbps Global DDoS Attacks

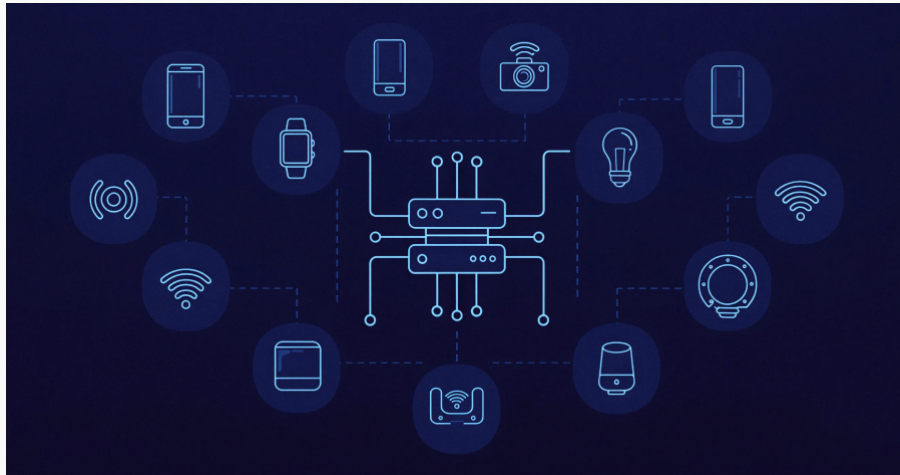
Enlace a la noticia: <https://thehackernews.com/2026/03/doj-disrupts-3-million-device-iot.html>

Medio: The Hacker News

Enlace al medio: <https://thehackernews.com>

Nacionalidad del medio: Internacional (EE. UU./Reino Unido)

Idioma de la noticia: Inglés



Breve resumen de la noticia: El Departamento de Justicia de EE. UU. anunció la disrupción de la infraestructura de comando y control (C2) de varias botnets de IoT (como AISURU y Kimwolf) que fueron utilizadas para lanzar ataques DDoS globales récord de 31.4 Tbps. Esta operación involucró a autoridades de Canadá y Alemania, así como a firmas privadas como Cloudflare y Akamai en la investigación. Los atacantes explotaron dispositivos IoT comprometidos para crear una red de botnets masiva.

Relación con la amenaza: Esta noticia describe un incidente de ciberseguridad masivo donde botnets basadas en dispositivos IoT (como cámaras, routers y televisores inteligentes) se convirtieron en herramientas para ataques DDoS a gran escala. La vulnerabilidad clave reside en el uso de estos dispositivos comprometidos para acceder a redes locales y explotar redes proxy residenciales.

¿Existe CVE o CWE asociado a la noticia? La noticia menciona vulnerabilidades relacionadas con proveedores de proxy (como IPIDEA) y la exposición de Android Debug Bridge (ADB), que fueron explotadas por los actores de la amenaza para obtener acceso a dispositivos de red local.

Impacto ocasionado por la amenaza en esta noticia: Los ataques generaron tráfico máximo equivalente a "la población combinada del Reino Unido, Alemania y España" simultáneamente navegando una dirección web, logrando tasas de ataque que superaron los 31.4 Tbps. Estos ataques pueden paralizar la infraestructura de Internet central, causar degradación significativa del servicio para los ISPs y sobrecargar los servicios de mitigación basados en la nube.

Capítulo 6

Malware en dispositivos móviles

Detalles de la Noticia

Breve descripción de la amenaza:

SparkCat es un malware avanzado que afecta a dispositivos móviles, capaz de robar frases de recuperación de billeteras de criptomonedas y otros datos sensibles mediante el uso de OCR sobre imágenes almacenadas en la galería del dispositivo. Se infiltra en aplicaciones aparentemente legítimas, incluso dentro de tiendas oficiales como Google Play y App Store, operando de forma sigilosa y difícil de detectar.

Fecha de la noticia:

11 de mayo de 2025

Título de la noticia: [SparkCat: El malware que pone en jaque la seguridad cripto y móvil](#)

Enlace a la noticia: [Acceder a la noticia](#)

Medio:

Android Guías

Enlace al medio: <https://androidguias.com>

Nacionalidad del medio:

España

Idioma de la noticia:

Español

Pequeña imagen de la noticia:

**Breve resumen de la noticia:**

La noticia describe el malware SparkCat, una amenaza sofisticada dirigida principalmente al robo de información relacionada con criptomonedas. Este malware utiliza tecnología OCR y aprendizaje automático para analizar imágenes en dispositivos móviles en busca de frases de recuperación, credenciales y datos sensibles. Se distribuye a través de aplicaciones infectadas, incluso en tiendas oficiales, y ha afectado a miles de usuarios a nivel global.

Relación con la amenaza:

Está directamente relacionada con el malware en dispositivos móviles, ya que demuestra cómo los atacantes están evolucionando sus técnicas para aprovechar funcionalidades legítimas (como el acceso a la galería) y así robar información crítica sin ser detectados.

¿Existe CVE o CWE asociado a la noticia?

No se menciona explícitamente ningún CVE concreto en la noticia. Sin embargo, la amenaza podría relacionarse con debilidades del tipo CWE-522 (credenciales insuficientemente protegidas) o CWE-284 (control de acceso inadecuado), debido al abuso de permisos y almacenamiento inseguro de datos sensibles.

Impacto ocasionado por la amenaza en esta noticia:

El impacto es alto tanto a nivel individual como global. Los usuarios pueden perder completamente sus fondos en criptomonedas, además de sufrir robo de identidad y exposición de datos personales. A nivel empresarial, puede provocar brechas de seguridad, pérdida de reputación y consecuencias legales. También afecta a la confianza en las tiendas oficiales de aplicaciones, evidenciando que no son totalmente seguras.